

Zeppelin-AppSec: Modelo de Evolução e Instrumento
de Diagnóstico para Segurança Contínua de Software
Instituto Federal do Espírito Santo (IFES)

Felipe Pereira

Serra – ES, 2026

Resumo

A transição contínua das organizações de desenvolvimento de software rumo a ciclos de entrega ágeis e automatizados (DevSecOps) expõe limitações severas nos modelos tradicionais de maturidade em segurança de aplicações (AppSec), como OWASP SAMM e OWASP DSOMM. Tais modelos sofrem de alta fricção avaliativa e complexidade de aplicação. Para solucionar essa classe de problemas, esta dissertação conduzida sob a metodologia *Design Science Research* (DSR) apresenta o instrumento **Zeppelin-AppSec** e seu modelo evolutivo subjacente **StH-AppSec** (*Stairway to Heaven for AppSec*). O artefato condensa 250 atividades do DSOMM v5.0.2 e 100% das práticas do SAMM v2.0 em um catálogo leve de 40 afirmações atômicas e simplificadas focadas na Experiência do Desenvolvedor (DX). A quantificação da maturidade adota a escala de institucionalização oficial (AL0 a AL4), cujos pesos numéricos permitem calcular o Grau de Adoção (AD) por dimensão e global. A avaliação empírica do artefato foi executada em três squads industriais classificadas segundo o Modelo Purdue (ISA-95): Squad A (Nível 2 – OT / Controle de Processos), Squad B (Nível 3 – MES / Gestão de Operações) e Squad C (Nível 4 – ERP / TI Corporativa), com uma única avaliação por squad. Os resultados demonstraram que o instrumento apresenta alta exequibilidade (< 30 minutos de preenchimento) e apurada capacidade de discriminação de maturidade entre níveis de automação industrial (Squad A: $AD = 20,3\%$; Squad B: $AD = 47,0\%$; Squad C: $AD = 88,7\%$).

Palavras-chave: Design Science Research. Segurança Contínua. DevSecOps. OWASP SAMM. OWASP DSOMM. Modelo Purdue. Grau de Adoção.

Abstract

The continuous transition of software development organizations toward agile and automated delivery cycles (DevSecOps) exposes severe limitations in traditional application security (AppSec) maturity models, such as OWASP SAMM and OWASP DSOMM. These models suffer from high evaluation friction and application complexity. To address this class of problems, this master’s dissertation, conducted under the Design Science Research (DSR) methodology, presents the **Zeppelin-AppSec** diagnostic instrument and its underlying evolutionary model, **StH-AppSec** (*Stairway to Heaven for AppSec*). The artifact condenses 250 activities from DSOMM v5.0.2 and 100% of SAMM v2.0 practices into a lightweight catalog of 40 atomic, simplified statements focused on Developer Experience (DX). Maturity quantification adopts the official institutionalization scale (AL0 to AL4), whose numeric weights allow computing the Adoption Degree (AD) per dimension and overall. Empirical evaluation of the artifact was conducted across three industrial squads classified according to the Purdue Model (ISA-95): Squad A (Level 2 – OT / Process Control), Squad B (Level 3 – MES / Operations Management), and Squad C (Level 4 – ERP / Corporate IT), with a single assessment per squad. Results demonstrated high feasibility (< 30 minutes completion time) and fine-grained capability to discriminate maturity across industrial automation levels (Squad A: $AD = 20.3\%$; Squad B: $AD = 47.0\%$; Squad C: $AD = 88.7\%$).

Keywords: Design Science Research. Continuous Security. DevSecOps. OWASP SAMM. OWASP DSOMM. Purdue Model. Adoption Degree.

Sumário

Resumo	1
Abstract	2
1 Introdução	5
1.1 Contextualização e Motivação	5
1.2 Definição do Problema e Classe de Problemas em AppSec	5
1.3 Objetivos	6
1.3.1 Objetivo Geral	6
1.3.2 Objetivos Específicos	6
1.4 Contribuições Esperadas	6
1.5 Organização do Texto	7
2 Método de Pesquisa: Design Science Research	8
2.1 Fundamentação Metodológica	8
2.2 Articulação dos Três Ciclos	8
2.3 Requisitos do Artefato (R) e Critérios de Avaliação (C)	9
3 Ciclo de Design e Learning Iterations	10
3.1 Visão Geral do Ciclo de Design	10
3.2 Primeira Learning Iteration: Formalização do Modelo Evolutivo StH-AppSec	10
3.2.1 Propósito e Conceituação	10
3.3 Segunda Learning Iteration: Construção do Instrumento e Catálogo Atômico	11
3.3.1 Arquitetura, Atomização e Eliminação da Fricção DX	11
3.3.2 Catálogo Consolidado de 40 Afirmações e Mapeamento Normativo .	11
3.4 Terceira Learning Iteration: Métricas e Escala AL0–AL4	19
3.4.1 Escala Oficial de Institucionalização (AL0 a AL4)	19
3.4.2 Cálculo do Grau de Adoção (AD)	20
4 Final Learning Iteration: Avaliação Empírica no Contexto Industrial	21
4.1 Contexto e Caracterização das Squads	21
4.2 Planejamento do Estudo e Protocolo Misto	21

4.3	Execução, Coleta de Dados e Resultados	22
4.3.1	Resumo Geral e Comparativo por Dimensão SMAF	22
4.3.2	Análise Detalhada da Squad A (Nível 2 — OT / Controle de Processos)	22
4.3.3	Análise Detalhada da Squad B (Nível 3 — MES / Gestão de Operações)	24
4.3.4	Análise Detalhada da Squad C (Nível 4 — ERP / TI Corporativa) .	25
4.4	Avaliação dos Requisitos (<i>R</i>) e Critérios (<i>C</i>)	27
5	Discussão e Considerações Finais	28
5.1	Contribuições para a Base de Conhecimento (Ciclo de Rigor)	28
5.2	Implicações Práticas e de Gestão (Ciclo de Relevância)	28
5.3	Ameaças à Validade	28
5.4	Síntese das Realizações	29
5.5	Trabalhos Futuros	29

Capítulo 1

Introdução

1.1 Contextualização e Motivação

A aceleração da transformação digital e a adoção generalizada da Engenharia de Software Contínua (CSE – *Continuous Software Engineering*) redefiniram os ritmos de desenvolvimento e entrega de software (Olsson et al., 2012; Júnior et al., 2022). Contudo, a velocidade alcançada por pipelines de Integração Contínua e Implantação Contínua (CI/CD) frequentemente colide com os processos tradicionais de segurança da informação, que historicamente operam de maneira reativa, pontual e desacoplada do fluxo de trabalho dos desenvolvedores (Moyón et al., 2024; Nägele et al., 2023).

Para superar esse impasse, o paradigma do DevSecOps advoga a integração contínua e automatizada de práticas de segurança ao longo de todo o ciclo de vida de desenvolvimento de software (SDLC) (Brasoveanu et al., 2022; Voggenreiter et al., 2024). No entanto, orientar as equipes ágeis nessa transição exige instrumentos de diagnóstico de maturidade que sejam simultaneamente rigorosos sob o ponto de vista normativo e viáveis sob a perspectiva operacional da Experiência do Desenvolvedor (DX) (Fucci et al., 2024; Mihelič et al., 2024).

1.2 Definição do Problema e Classe de Problemas em AppSec

Apesar da disponibilidade de frameworks reconhecidos internacionalmente, como OWASP SAMM v2.0 e OWASP DSOMM v5.0.2, a avaliação prática de maturidade enfrenta dois gargalos críticos na indústria:

1. **Alta Complexidade Avaliativa e Burocracia:** questionários extensos contendo dezenas ou centenas de perguntas geram exaustão cognitiva, demandando auditorias presenciais demoradas que interrompem o ritmo das *sprints* (Brasoveanu et al., 2022; Fucci et al., 2024).

2. **Falta de Alinhamento com a Experiência do Desenvolvedor (DX)**: a presença de afirmações compostas (que reúnem múltiplas práticas em um único item) impõe o “Dilema do Respondente”, forçando respostas imprecisas quando o time adota uma prática, mas não a outra.

Esta pesquisa trata, portanto, da seguinte **Classe de Problemas**: *Como diagnosticar empiricamente o grau de maturidade em Segurança Contínua de Software em equipes ágeis e industriais, reduzindo a complexidade avaliativa por meio de instrumentos leves e ancorados em normas internacionais?*

1.3 Objetivos

1.3.1 Objetivo Geral

Projetar, formalizar e avaliar empiricamente um artefato de diagnóstico leve — denominado **Zeppelin-AppSec** — fundamentado no modelo evolutivo **StH-AppSec**, capaz de mensurar a maturidade em Segurança Contínua de software em squads industriais e ágeis.

1.3.2 Objetivos Específicos

1. Formular o modelo evolutivo **StH-AppSec**, adaptando os cinco estágios do modelo *Stairway to Heaven* para o domínio da segurança de aplicações.
2. Sintetizar as 250 atividades do OWASP DSOMM v5.0.2 e as práticas do OWASP SAMM v2.0 em um catálogo consolidado de 40 afirmações atômicas e simplificadas focadas em DX.
3. Desenvolver a métrica matemática de **Grau de Adoção (AD)**, a partir da escala de institucionalização oficial AL0 a AL4 e de seus pesos numéricos.
4. Avaliar empiricamente o artefato em três squads industriais classificadas segundo os Níveis 2, 3 e 4 do Modelo Purdue (ISA-95), com uma única avaliação por squad.

1.4 Contribuições Esperadas

As contribuições desta pesquisa compreendem: (i) o modelo evolutivo **StH-AppSec**, que estende a teoria do *Stairway to Heaven* ao domínio de AppSec; e (ii) o instrumento **Zeppelin-AppSec**, catálogo leve e rastreável às normas de mercado.

1.5 Organização do Texto

O Capítulo 2 descreve o método de pesquisa e a articulação dos três ciclos da DSR. O Capítulo 3 apresenta as *learning iterations* de concepção do artefato. O Capítulo 4 relata a *final learning iteration*, com a avaliação empírica no contexto industrial. O Capítulo 5 consolida as discussões e as considerações finais.

Capítulo 2

Método de Pesquisa: Design Science Research

2.1 Fundamentação Metodológica

A condução desta dissertação é fundamentada na metodologia *Design Science Research* (DSR), orientada à criação e avaliação de artefatos inovadores projetados para resolver problemas práticos relevantes (Núñez et al., 2020; Khan et al., 2022). O processo metodológico estrutura-se sobre as seis atividades de Peffers et al. (2007), articuladas aos três ciclos propostos por Hevner (2007) e organizadas em iterações de aprendizagem conforme Barcellos et al. (2022).

2.2 Articulação dos Três Ciclos

- **Ciclo de Relevância:** conecta o ambiente industrial (squads operacionais em níveis do Modelo Purdue) às necessidades de diagnóstico leve e sem fricção.
- **Ciclo de Design:** envolve iterações de aprendizagem (*learning iterations*) para concepção do modelo evolutivo StH-AppSec, construção do catálogo simplificado Zeppelin-AppSec e formulação do modelo matemático do Grau de Adoção (*AD*).
- **Ciclo de Rigor:** fundamenta as decisões de design nas normas consolidadas de mercado (OWASP SAMM v2.0, OWASP DSOMM v5.0.2, SMAF, Modelo Purdue ISA-95 e referencial de Engenharia de Software Contínua).

2.3 Requisitos do Artefato (R) e Critérios de Avaliação (C)

Para orientar o desenvolvimento e a validação no Ciclo de Design, foram estabelecidos três Requisitos de Design (R) e dois Critérios de Avaliação (C):

- $R1$ (**Simplicidade e DX**): o instrumento deve ser preenchido em menos de 30 minutos, utilizando afirmações atômicas e unívocas.
- $R2$ (**Ancoragem Normativa Ampla**): o catálogo deve manter rastreabilidade bidirecional completa com 100% das práticas do OWASP SAMM v2.0 e os 250 IDs de atividades do OWASP DSOMM v5.0.2.
- $R3$ (**Adequação ao Modelo Purdue**): o diagnóstico deve demonstrar capacidade de discriminar a maturidade técnica em diferentes camadas de automação industrial (OT, MES e ERP).

Os Critérios de Avaliação compreendem: $C1$ (Exequibilidade/DX) e $C2$ (Capacidade Discriminatória de Maturidade).

Capítulo 3

Ciclo de Design e Learning Iterations

3.1 Visão Geral do Ciclo de Design

O desenvolvimento do artefato seguiu um processo iterativo no Ciclo de Design da DSR, composto por três *learning iterations* estruturadas que evoluíram progressivamente a partir dos requisitos teóricos e operacionais mapeados na literatura.

3.2 Primeira Learning Iteration: Formalização do Modelo Evolutivo StH-AppSec

3.2.1 Propósito e Conceituação

A primeira iteração tratou da adaptação do modelo conceitual *Stairway to Heaven* (Olsson et al., 2012; Júnior et al., 2022) para o domínio da Segurança Contínua. O modelo **StH-AppSec** organiza a jornada de maturidade em cinco estágios evolutivos contínuos:

- **Estágio A — AppSec Reativa / Tradicional (*Reactive AppSec*)**: segurança tratada como auditoria pontual e reativa no final do ciclo de vida, sem integração ao backlog ágil.
- **Estágio B — AppSec Ágil (*Agile AppSec*)**: integração no time ágil com Security Champions, *Breakout Action Groups* (BAGs), Security Stories e revisões de código na squad.
- **Estágio C — Integração Contínua Segura (CSI)**: automação técnica no servidor de CI, executando verificações automáticas de SAST, SCA, *Threat Modeling as Code* e Quality Gates no build.
- **Estágio D — Implantação Contínua Segura (CSD)**: automação na pipeline de CD, contemplando análise de Infraestrutura como Código (IaC), cofres de segredos (*Vaults*) e DAST em *staging*.

- **Estágio E — Operação Contínua de Segura (CSO):** observabilidade em produção, centralização de logs em SIEM, WAF, escaneamentos agendados e resiliência operacional.

3.3 Segunda Learning Iteration: Construção do Instrumento e Catálogo Atômico

3.3.1 Arquitetura, Atomização e Eliminação da Fricção DX

A segunda iteração focou em resolver a inviabilidade operacional dos questionários extensos. Para eliminar o “Dilema do Respondente” presente em afirmações compostas, o catálogo foi refinado e desmembrado em **40 afirmações atômicas e unívocas**, em que cada item avalia uma única prática técnica clara.

3.3.2 Catálogo Consolidado de 40 Afirmações e Mapeamento Normativo

A Tabela 3.1 apresenta o catálogo consolidado do instrumento Zeppelin-AppSec, detalhando a correspondência com os estágios do StH-AppSec, as dimensões do framework SMAF (Brasoveanu et al., 2022), as referências do OWASP SAMM v2.0 e o mapeamento integral de todos os IDs do OWASP DSOMM v5.0.2 (IDs diretos e correlatos/absorvidos).

Tabela 3.1: Catálogo consolidado das 40 afirmações atômicas do Zeppelin-AppSec e mapeamento normativo completo com OWASP SAMM v2.0 e OWASP DSOMM v5.0.2 (IDs diretos e correlatos).

Cód.	Declaração simplificada (foco em DX e atomização)	Estágio StH	Dimensão SMAF	Ref. OWASP SAMM v2.0	Ref. OWASP DSOMM v5.0.2 (IDs diretos e correlatos)
AO.01	Regras técnicas e objetivos de segurança documentados e divulgados para todas as squads.	Estágio A (Reactive)	Governança	Strategy & Metrics (SM-1A, SM-2A), Policy & Compliance (PC-1A, PC-2A)	Culture and Organization → Design (ID: 071) [Correlatos: IDs 008, 062, 133]

Continua na próxima página

Cód.	Declaração simplificada (foco em DX e atomização)	Estágio StH	Dimensão SMAF	Ref. OWASP SAMM v2.0	Ref. OWASP DSOMM v5.0.2 (IDs diretos e correlatos)
AO.02	Mapeamos a criticidade e o perfil de risco de cada aplicação (sensibilidade dos dados e exposição) para calibrar os requisitos de segurança.	Estágio A (Reactive)	Governança	Threat Assessment (TA-1A, TA-2A)	N/A (atividade nativa do OWASP SAMM) [Correlatos: IDs 095, 159]
VER.01	Realizamos testes de invasão (pentests) manuais ou auditorias formais de segurança antes de lançamentos críticos.	Estágio A (Reactive)	Testes e Verificação	Security Testing (ST-1B, ST-2B), Policy & Compliance (PC-1B)	Dynamic depth for infrastructure (IDs: 210, 214), Test Intensity (ID: 247) [Correlatos: IDs 209, 211, 213, 215, 216]
GOV.01	Possuímos Security Champions ou grupos de ação (BAGs) formalizados e atuando diretamente junto às squads.	Estágio B (Agile)	Governança	Education & Guidance (EG-1A, EG-1B)	Education and Guidance (IDs: 077, 078) [Correlatos: IDs 082, 088, 089]
GOV.02	Promovemos treinamentos e capacitações periódicas em codificação segura (ex.: OWASP Top 10) para os desenvolvedores.	Estágio B (Agile)	Governança	Education & Guidance (EG-2A, EG-2B)	Education and Guidance (IDs: 079, 080, 081) [Correlatos: IDs 090, 092, 093]
ARQ.01	Discutimos requisitos de segurança no planejamento da sprint por meio de estórias de segurança (Security Stories) ou Threat Poker.	Estágio B (Agile)	Arquitetura e Design	Security Requirements (SR-1A, SR-2A), Threat Assessment (TA-1B, TA-2B)	Design (IDs: 070, 072, 073) [Correlatos: IDs 012, 013, 017, 031, 032]

Continua na próxima página

Cód.	Declaração simplificada (foco em DX e atomização)	Estágio StH	Dimensão SMAF	Ref. OWASP SAMM v2.0	Ref. OWASP DSOMM v5.0.2 (IDs diretos e correlatos)
ARQ.02	Adotamos padrões e princípios formais de arquitetura segura (ex.: defesa em camadas, menor privilégio).	Estágio B (Agile)	Arquitetura e Design	Secure Architecture (SA-1A, SA-1B), Architecture Assessment (AA-1A, AA-1B)	Application Hardening (IDs: 098, 101) [Correlatos: IDs 102, 105, 106, 115, 116]
ARQ.03	Utilizamos bibliotecas corporativas padronizadas e validadas para autenticação, autorização e criptografia.	Estágio B (Agile)	Arquitetura e Design	Secure Architecture (SA-2A, SA-2B), Architecture Assessment (AA-2A, AA-2B)	Identity and Access Management (IDs: 118, 123) [Correlatos: IDs 119, 120, 124, 127, 128, 130, 134, 135, 137, 144, 145]
ARQ.04	Possuímos diretrizes técnicas e governança para o uso seguro de Inteligência Artificial Generativa e LLMs no desenvolvimento.	Estágio B (Agile)	Arquitetura e Design	N/A (Filtro F-ESC / inovação recente)	Agentic AI → Guidance (IDs: 008, 016), Data Protection (IDs: 002, 005) [Correlatos: IDs 001, 004, 006, 007, 009, 010, 011, 014, 015, 018–030, 033–036, 039, 040]
COD.01	Utilizamos guias de código seguro e linters/analísadores estáticos de segurança integrados à IDE local dos desenvolvedores.	Estágio B (Agile)	Desenvol. e Revisão	Secure Build (SB-1A), Security Testing (ST-1A)	Education and Guidance (ID: 083), Development and Source Control (ID: 108) [Correlatos: IDs 106, 107, 109, 110]

Continua na próxima página

Cód.	Declaração simplificada (foco em DX e atomização)	Estágio StH	Dimensão SMAF	Ref. OWASP SAMM v2.0	Ref. OWASP DSOMM v5.0.2 (IDs diretos e correlatos)
COD.02	Realizamos revisão de código por pares (Peer Review / PR Review) com foco explícito na identificação de falhas de segurança.	Estágio B (Agile)	Desenvol. e Revisão	Code Review (L1)	Development and Source Control (ID: 113), Static depth for applications (ID: 221) [Correlatos: IDs 111, 112, 222, 229]
COD.03	Utilizamos mecanismos automáticos (ex.: pre-commit hooks) para impedir o envio acidental de credenciais e segredos ao repositório.	Estágio B (Agile)	Desenvol. e Revisão	Secure Deployment (SD-1B), Secure Architecture (L2)	Static depth for infrastructure (IDs: 234, 235), Application Hardening (IDs: 099, 100) [Correlatos: IDs 094, 096, 097]
COD.04	Registramos e gerenciamos as vulnerabilidades identificadas diretamente no backlog principal da squad.	Estágio B (Agile)	Desenvol. e Revisão	Defect Mgmt (DM-1A, DM-2A, DM-3A)	Consolidation (IDs: 193, 194) [Correlatos: IDs 186, 187, 198, 199, 200]
ARQ.05	Executamos a modelagem de ameaças de forma contínua e automatizada no pipeline de CI (Threat Modeling as Code).	Estágio C (CSI)	Arquitetura e Design	Threat Assessment (TA-3B)	Design (IDs: 074, 075) [Correlato: ID 076]
ARQ.06	Acompanhamos métricas formais de desempenho em AppSec (ex.: MTTR de vulnerabilidades, densidade de defeitos).	Estágio C (CSI)	Arquitetura e Design	Strategy & Metrics (SM-1B, SM-2B), Defect Mgmt (DM-2B)	Test KPI (IDs: 176, 178, 181) [Correlatos: IDs 171–175, 177, 179, 180, 182]
COD.05	Escrevemos testes automatizados de segurança (Security Unit Tests / Security TDD) para validar lógicas críticas do código.	Estágio C (CSI)	Desenvol. e Revisão	Requirements-driven Testing (RT-1A, RT-2A)	Application tests (IDs: 183, 184) [Correlatos: IDs 038, 121, 185, 186]

Continua na próxima página

Cód.	Declaração simplificada (foco em DX e atomização)	Estágio StH	Dimensão SMAF	Ref. OWASP SAMM v2.0	Ref. OWASP DSOMM v5.0.2 (IDs diretos e correlatos)
IND.01	O processo de compilação (build) é 100% automatizado, isolado e rastreável no servidor de CI a cada commit.	Estágio C (CSI)	Construção e Impl.	Secure Build (SB-1A), Environment Mgmt (EM-1A), Secure Deployment (SD-1A)	Build (ID: 041), Deployment (IDs: 047, 048), Development and Source Control (IDs: 107, 108) [Correlatos: IDs 042, 049, 052, 053, 059, 138, 139, 148]
IND.02	Ferramentas de SCA escaneiam bibliotecas open-source no CI, identificando vulnerabilidades e bloqueando licenças não autorizadas.	Estágio C (CSI)	Construção e Impl.	Environment Mgmt (EM-1B), Secure Build (SB-1B, SB-2A, SB-2B)	Build (IDs: 043, 044), Patch Management (IDs: 062, 063), Static depth for applications (IDs: 218, 223, 244) [Correlatos: IDs 056, 064, 068, 217, 219, 225, 226, 227]
VER.02	Ferramentas de SAST rodam automaticamente no pipeline de CI a cada Pull Request.	Estágio C (CSI)	Testes e Verificação	Security Testing (ST-2A, ST-3A), Secure Build (SB-2A)	Static depth for applications (IDs: 224, 225, 228) [Correlatos: IDs 229, 231, 237, 240]
VER.03	Ferramentas de varredura de segurança em imagens de contêineres/Docker rodam automaticamente no pipeline de CI.	Estágio C (CSI)	Testes e Verificação	Secure Build (SB-2A), Security Testing (ST-2A)	Static depth for infrastructure (IDs: 236, 238, 245), Test Intensity (ID: 247) [Correlatos: IDs 241, 242, 243, 246]
VER.04	Utilizamos Quality Gates no CI para bloquear automaticamente builds ou PRs que contenham vulnerabilidades graves.	Estágio C (CSI)	Testes e Verificação	Requirements-driven Testing (RT-3A), Secure Build (SB-3A), Issue Tracking (L2)	Test Intensity (IDs: 248, 249), Consolidation (IDs: 188, 193, 194) [Correlatos: IDs 037, 064, 187, 191, 195, 196, 250]

Continua na próxima página

Cód.	Declaração simplificada (foco em DX e atomização)	Estágio StH	Dimensão SMAF	Ref. OWASP SAMM v2.0	Ref. OWASP DSOMM v5.0.2 (IDs diretos e correlatos)
ARQ.07	Validamos a conformidade regulatória (ex.: LGPD, PCI) de forma automatizada no pipeline de CD (Compliance as Code).	Estágio D (CSD)	Arquitetura e Design	Policy & Compliance (PC-1B, PC-2B, PC-3A), Architecture Assessment (AA-3A)	Static depth for infrastructure (IDs: 239, 240) [Correlatos: IDs 158, 163]
ARQ.08	Possuímos playbooks automatizados de resposta e contenção de incidentes de segurança integrados ao CD.	Estágio D (CSD)	Arquitetura e Design	Incident Management (IM-1A, IM-2A, IM-2B)	Incident Management (IDs: 169, 212) [Correlatos: IDs 158, 163]
IND.03	Gerenciamos e injetamos credenciais e segredos dinamicamente em runtime por meio de cofres centralizados (Secrets Vaults).	Estágio D (CSD)	Construção e Impl.	Secure Deployment (SD-2B, SD-3B)	Build (IDs: 045, 046) [Correlatos: IDs 125, 128]
IND.04	Assinamos digitalmente artefatos de código, compilações e imagens de contêineres antes do deploy para garantir a integridade.	Estágio D (CSD)	Construção e Impl.	Secure Build (SB-3B), Secure Deployment (SD-3B)	Deployment (IDs: 051, 055) [Correlato: ID 131]
IND.05	Analisamos estaticamente scripts de Infraestrutura como Código (IaC Scanning: Terraform/Ansible) no pipeline de integração.	Estágio D (CSD)	Construção e Impl.	Secure Deployment (SD-2A, SD-3A)	Infrastructure Hardening (IDs: 133, 136, 141) [Correlatos: IDs 132, 140, 143]

Continua na próxima página

Cód.	Declaração simplificada (foco em DX e atomização)	Estágio StH	Dimensão SMAF	Ref. OWASP SAMM v2.0	Ref. OWASP DSOMM v5.0.2 (IDs diretos e correlatos)
IND.06	Provisionamos ambientes e serviços utilizando exclusivamente imagens previamente homologadas e endurecidas (Golden Images).	Estágio D (CSD)	Construção e Impl.	Environment Mgmt (EM-2A), Secure Deployment (SD-2A)	Infrastructure Hardening (ID: 142), Patch Management (IDs: 065, 067) [Correlatos: IDs 066, 069, 147]
VER.05	Testes dinâmicos (DAST), análises de API e IAST rodam automaticamente contra a aplicação em staging antes do deploy.	Estágio D (CSD)	Testes e Verificação	Requirements-driven Testing (RT-2A, RT-3B), Security Testing (ST-3A)	Dynamic depth for applications (IDs: 201–206), Static depth for applications (ID: 220) [Correlatos: IDs 207, 208]
VER.06	Utilizamos ferramentas de Gestão de Postura de Segurança em Nuvem (CSPM) para detectar desvios de configuração em tempo real.	Estágio D (CSD)	Testes e Verificação	Architecture Assessment (AA-3B), Environment Mgmt (EM-3A)	Dynamic depth for infrastructure (IDs: 210, 212) [Correlatos: IDs 189, 190]
VER.07	Utilizamos inteligência de ameaças (ex.: EPSS, CISA KEV) para priorizar correções com base na explorabilidade real.	Estágio D (CSD)	Testes e Verificação	Defect Mgmt (DM-3B)	Consolidation (IDs: 189, 192, 195, 197) [Correlato: ID 192]
OPE.01	Centralizamos e correlacionamos logs de segurança de todas as aplicações e microserviços em produção (SIEM / SOC).	Estágio E (CSO)	Operações e Obs.	Incident Management (IM-2A, IM-3A)	Logging (IDs: 152, 153, 154, 158), Monitoring (IDs: 160, 162, 163) [Correlatos: IDs 151, 156, 161, 164–168]

Continua na próxima página

Cód.	Declaração simplificada (foco em DX e atomização)	Estágio StH	Dimensão SMAF	Ref. OWASP SAMM v2.0	Ref. OWASP DSOMM v5.0.2 (IDs diretos e correlatos)
OPE.02	Protegemos as aplicações em produção com soluções de borda e runtime (WAF, API Gateways e Rate Limiting).	Estágio (CSO)	E	Operações e Obs.	Environment Mgmt (EM-2B, EM-3B) Infrastructure Hardening (IDs: 132, 146, 150), Application Hardening (ID: 104) [Correlatos: IDs 103, 117, 122, 126, 129]
OPE.03	Mantemos processos contínuos de aplicação de patches de segurança e testes periódicos de restauração de backups.	Estágio (CSO)	E	Operações e Obs.	Operational Resilience (OR-1A, OR-2A, OR-3A) Patch Management (IDs: 062, 065) [Correlatos: IDs 061, 151]
OPE.04	Executamos varreduras periódicas agendadas de SAST e SCA no repositório de produção para detectar novas CVEs em código antigo.	Estágio (CSO)	E	Operações e Obs.	Environment Mgmt (EM-1B, EM-2B), Security Testing (ST-2A) Patch Management (IDs: 062, 065), Static depth for applications (IDs: 218, 225, 227) [Correlatos: IDs 063, 067, 069, 217, 219, 226, 231]
GOV.03	Oferecemos treinamentos avançados de segurança técnica focados nas tecnologias e frameworks específicos da empresa.	Estágio (CSO)	E	Governança	Education & Guidance (EG-2A, EG-3B) Education and Guidance (IDs: 084, 085, 086) [Correlatos: IDs 081, 082]
GOV.04	Atualizamos continuamente as diretrizes e controles de AppSec com base nas lições aprendidas de incidentes passados.	Estágio (CSO)	E	Governança	Defect Mgmt (DM-1B), Strategy & Metrics (SM-3B) Education and Guidance (ID: 087) [Correlatos: IDs 087, 091]
OPE.05	Possuímos observabilidade e monitoramento de ataques e anomalias em tempo real no ambiente de produção.	Estágio (CSO)	E	Operações e Obs.	Incident Management (IM-3B) Logging (IDs: 155, 157), Monitoring (ID: 170) [Correlatos: IDs 150, 166]

Continua na próxima página

Cód.	Declaração simplificada (foco em DX e atomização)	Estágio StH	Dimensão SMAF	Ref. OWASP SAMM v2.0	Ref. OWASP DSOMM v5.0.2 (IDs diretos e correlatos)
OPE.06	Executamos experimentos de Engenharia do Caos voltados à segurança ou mantemos programas de Bug Bounty.	Estágio E (CSO)	Operações e Obs.	Security Testing (ST-3B)	Infrastructure Hardening (ID: 149) [Correlato: ID 170]
OPE.07	Realizamos análise forense e pós-mortem após incidentes para retroalimentar novos requisitos de segurança.	Estágio E (CSO)	Operações e Obs.	Threat Assessment (TA-3A), Incident Mgmt (IM-3A)	Education and Guidance (ID: 087) [Correlatos: IDs 050, 054, 091]
OPE.08	Utilizamos estratégias de implantação segura (Canary / Blue-Green) com rollback automático em caso de falha de segurança.	Estágio E (CSO)	Operações e Obs.	Secure Deployment (SD-3A)	Deployment (IDs: 058, 060) [Correlatos: IDs 057, 061]

3.4 Terceira Learning Iteration: Métricas e Escala AL0–AL4

3.4.1 Escala Oficial de Institucionalização (AL0 a AL4)

A quantificação da maturidade adota a escala de institucionalização oficial do Zeppelin (Júnior et al., 2022), composta por cinco níveis ordenados e com atribuição de pesos numéricos:

- **AL4 — Institucionalizada** (100%; 1,00): prática formalmente definida, automatizada quando aplicável e executada sistematicamente em todas as soluções.
- **AL3 — Processo Definido** (60%; 0,60): prática padronizada e documentada corporativamente, mas de adoção opcional pelos times.
- **AL2 — Projeto / Produto** (30%; 0,30): execução pontual/*ad hoc* em um projeto específico por iniciativa individual.

- **AL1 — Abandonada** (10%; 0,10): prática testada no passado, mas descontinuada por complexidade ou excesso de falsos positivos (reconhece capacidade aprendida).
- **AL0 — Não Adotada** (0%; 0,00): prática nunca implementada na organização.

3.4.2 Cálculo do Grau de Adoção (AD)

Cada squad responde ao questionário uma única vez, de modo que o peso de cada afirmação é extraído diretamente do nível de adoção (AL) assinalado. O Grau de Adoção de um agrupamento k de afirmações (dimensão SMAF ou estágio StH-AppSec) é a média simples dos pesos das afirmações que o compõem:

$$AD_k = \frac{\sum_{i \in k} \text{peso}(AL_i)}{n_k} \times 100\% \quad (3.1)$$

onde n_k é o número de afirmações do agrupamento k e $\text{peso}(AL_i) \in \{0,00; 0,10; 0,30; 0,60; 1,00\}$. O Grau de Adoção global da squad (AD_{global}) é a média simples dos AD_k das seis dimensões do SMAF:

$$AD_{\text{global}} = \frac{1}{6} \sum_{k \in \text{SMAF}} AD_k \quad (3.2)$$

Capítulo 4

Final Learning Iteration: Avaliação Empírica no Contexto Industrial

4.1 Contexto e Caracterização das Squads

A validação empírica do artefato foi realizada em três squads operacionais (anonimizadas por razões de confidencialidade) enquadradas nos níveis de arquitetura de automação do Modelo Purdue (ISA-95):

- **Squad A (Nível 2 — OT / Controle de Processos):** responsável por softwares de supervisão de campo (SCADA, IHMs) e controle em tempo real. Ambiente caracterizado por alta criticidade operacional, restrições rígidas de latência e forte orientação a sistemas legados.
- **Squad B (Nível 3 — MES / Gestão de Operações de Manufatura):** desenvolve sistemas de rastreabilidade de produção, controle de lotes e historiadores de dados, atuando na ponte entre o chão de fábrica (OT) e a TI corporativa.
- **Squad C (Nível 4 — ERP / TI Corporativa):** gestão de sistemas de logística, portais corporativos e soluções em nuvem, operando sob arquitetura moderna de microsserviços e integração contínua.

4.2 Planejamento do Estudo e Protocolo Misto

Cada squad foi avaliada por meio de uma única aplicação do questionário de 40 afirmações, respondida por um representante da equipe, totalizando três avaliações. O protocolo combinou o preenchimento digital do survey com sessões qualitativas de *focus group* para avaliar a usabilidade e a utilidade diagnóstica.

4.3 Execução, Coleta de Dados e Resultados

4.3.1 Resumo Geral e Comparativo por Dimensão SMAF

A Tabela 4.1 consolida o Grau de Adoção (AD) por dimensão do SMAF e o AD global de cada squad, calculados a partir da avaliação única realizada em cada equipe sobre o catálogo de 40 afirmações atômicas.

Tabela 4.1: Resumo geral do diagnóstico Zeppelin-AppSec: Grau de Adoção (AD) por dimensão SMAF segundo o Modelo Purdue.

Dimensão SMAF	Squad A (N2 OT)	Squad B (N3 MES)	Squad C (N4 ERP)	Média geral
Governança	36,7%	55,0%	93,3%	61,7%
Arquitetura e Design	10,0%	37,5%	80,0%	42,5%
Desenvol. e Revisão	24,0%	54,0%	92,0%	56,7%
Construção e Impl.	13,3%	51,7%	100,0%	55,0%
Testes e Verificação	14,3%	40,0%	77,1%	43,8%
Operações e Obs.	23,8%	43,8%	90,0%	52,5%
Grau de Adoção global (AD_{global})	20,3%	47,0%	88,7%	52,0%

A Tabela 4.2 apresenta o AD segundo os estágios do modelo StH-AppSec, obtido com a mesma fórmula ao agrupar as afirmações pelo estágio a que pertencem no catálogo (Tabela 3.1), o que permite posicionar cada squad na trilha evolutiva.

Tabela 4.2: Grau de Adoção (AD) por estágio evolutivo do StH-AppSec segundo o Modelo Purdue.

Estágio StH-AppSec	Squad A (N2 OT)	Squad B (N3 MES)	Squad C (N4 ERP)
Estágio A – Reactive (3 itens)	60,0%	60,0%	86,7%
Estágio B – Agile (10 itens)	26,0%	54,0%	92,0%
Estágio C – CSI (8 itens)	10,0%	50,0%	85,0%
Estágio D – CSD (9 itens)	4,4%	31,1%	86,7%
Estágio E – CSO (10 itens)	23,0%	44,0%	88,0%

4.3.2 Análise Detalhada da Squad A (Nível 2 — OT / Controle de Processos)

A Tabela 4.3 traz o detalhamento item a item da avaliação da Squad A para todos os 40 itens atômicos.

Tabela 4.3: Detalhamento dos resultados do diagnóstico Zeppelin-AppSec para a Squad A (Nível 2 Purdue — OT).

Cód.	Dimensão	Nível de Adoção	Peso	AD (%)
AO.01	Governança	AL3	0,60	60%

Continua na próxima página

Cód.	Dimensão	Nível de Adoção	Peso	AD (%)
AO.02	Governança	AL3	0,60	60%
VER.01	Testes e Verificação	AL3	0,60	60%
GOV.01	Governança	AL2	0,30	30%
GOV.02	Governança	AL2	0,30	30%
ARQ.01	Arquitetura e Design	AL2	0,30	30%
ARQ.02	Arquitetura e Design	AL2	0,30	30%
ARQ.03	Arquitetura e Design	AL1	0,10	10%
ARQ.04	Arquitetura e Design	AL1	0,10	10%
COD.01	Desenvol. e Revisão	AL2	0,30	30%
COD.02	Desenvol. e Revisão	AL2	0,30	30%
COD.03	Desenvol. e Revisão	AL2	0,30	30%
COD.04	Desenvol. e Revisão	AL2	0,30	30%
ARQ.05	Arquitetura e Design	AL0	0,00	0%
ARQ.06	Arquitetura e Design	AL0	0,00	0%
COD.05	Desenvol. e Revisão	AL0	0,00	0%
IND.01	Construção e Impl.	AL2	0,30	30%
IND.02	Construção e Impl.	AL1	0,10	10%
VER.02	Testes e Verificação	AL2	0,30	30%
VER.03	Testes e Verificação	AL1	0,10	10%
VER.04	Testes e Verificação	AL0	0,00	0%
ARQ.07	Arquitetura e Design	AL0	0,00	0%
ARQ.08	Arquitetura e Design	AL0	0,00	0%
IND.03	Construção e Impl.	AL2	0,30	30%
IND.04	Construção e Impl.	AL1	0,10	10%
IND.05	Construção e Impl.	AL0	0,00	0%
IND.06	Construção e Impl.	AL0	0,00	0%
VER.05	Testes e Verificação	AL0	0,00	0%
VER.06	Testes e Verificação	AL0	0,00	0%
VER.07	Testes e Verificação	AL0	0,00	0%
OPE.01	Operações e Obs.	AL2	0,30	30%
OPE.02	Operações e Obs.	AL3	0,60	60%
OPE.03	Operações e Obs.	AL2	0,30	30%
OPE.04	Operações e Obs.	AL2	0,30	30%
GOV.03	Governança	AL1	0,10	10%
GOV.04	Governança	AL2	0,30	30%
OPE.05	Operações e Obs.	AL0	0,00	0%
OPE.06	Operações e Obs.	AL0	0,00	0%
OPE.07	Operações e Obs.	AL2	0,30	30%
OPE.08	Operações e Obs.	AL1	0,10	10%

A Squad A apresentou $AD_{\text{global}} = 20,3\%$, com maturidade concentrada no Estágio A ($AD = 60,0\%$) e queda acentuada nos estágios de automação: 26,0% no Estágio B, 10,0% no Estágio C (CSI) e 4,4% no Estágio D (CSD). Treze das 40 práticas foram assinaladas como AL0 (não adotadas), incluindo *Quality Gates*, DAST, IaC Scanning, CSPM e modelagem de ameaças como código; SAST e SCA no CI aparecem apenas de forma pontual (AL2) e abandonada (AL1), respectivamente. Os maiores níveis (AL3) concentram-se em práticas reativas ou de perímetro: documentação de regras de segurança (AO.01), mapeamento de criticidade das aplicações (AO.02), testes de invasão (VER.01) e proteção de borda com WAF e *API Gateways* (OPE.02). Por dimensão, a maior pontuação ocorreu em Governança (36,7%) e a menor em Arquitetura e Design (10,0%).

4.3.3 Análise Detalhada da Squad B (Nível 3 — MES / Gestão de Operações)

A Tabela 4.4 detalha a avaliação da Squad B (MES), cobrindo todos os 40 itens atômicos.

Tabela 4.4: Detalhamento dos resultados do diagnóstico Zeppelin-AppSec para a Squad B (Nível 3 Purdue — MES).

Cód.	Dimensão	Nível de Adoção	Peso	AD (%)
AO.01	Governança	AL3	0,60	60%
AO.02	Governança	AL3	0,60	60%
VER.01	Testes e Verificação	AL3	0,60	60%
GOV.01	Governança	AL3	0,60	60%
GOV.02	Governança	AL3	0,60	60%
ARQ.01	Arquitetura e Design	AL3	0,60	60%
ARQ.02	Arquitetura e Design	AL3	0,60	60%
ARQ.03	Arquitetura e Design	AL2	0,30	30%
ARQ.04	Arquitetura e Design	AL2	0,30	30%
COD.01	Desenvol. e Revisão	AL3	0,60	60%
COD.02	Desenvol. e Revisão	AL3	0,60	60%
COD.03	Desenvol. e Revisão	AL3	0,60	60%
COD.04	Desenvol. e Revisão	AL3	0,60	60%
ARQ.05	Arquitetura e Design	AL2	0,30	30%
ARQ.06	Arquitetura e Design	AL2	0,30	30%
COD.05	Desenvol. e Revisão	AL2	0,30	30%
IND.01	Construção e Impl.	AL4	1,00	100%
IND.02	Construção e Impl.	AL3	0,60	60%
VER.02	Testes e Verificação	AL3	0,60	60%

Continua na próxima página

Cód.	Dimensão	Nível de Adoção	Peso	AD (%)
VER.03	Testes e Verificação	AL3	0,60	60%
VER.04	Testes e Verificação	AL2	0,30	30%
ARQ.07	Arquitetura e Design	AL2	0,30	30%
ARQ.08	Arquitetura e Design	AL2	0,30	30%
IND.03	Construção e Impl.	AL3	0,60	60%
IND.04	Construção e Impl.	AL2	0,30	30%
IND.05	Construção e Impl.	AL2	0,30	30%
IND.06	Construção e Impl.	AL2	0,30	30%
VER.05	Testes e Verificação	AL2	0,30	30%
VER.06	Testes e Verificação	AL1	0,10	10%
VER.07	Testes e Verificação	AL2	0,30	30%
OPE.01	Operações e Obs.	AL3	0,60	60%
OPE.02	Operações e Obs.	AL3	0,60	60%
OPE.03	Operações e Obs.	AL3	0,60	60%
OPE.04	Operações e Obs.	AL3	0,60	60%
GOV.03	Governança	AL2	0,30	30%
GOV.04	Governança	AL3	0,60	60%
OPE.05	Operações e Obs.	AL1	0,10	10%
OPE.06	Operações e Obs.	AL1	0,10	10%
OPE.07	Operações e Obs.	AL3	0,60	60%
OPE.08	Operações e Obs.	AL2	0,30	30%

A Squad B obteve $AD_{\text{global}} = 47,0\%$, com pontuações próximas nos Estágios A (60,0%), B (54,0%) e C (50,0%) e redução no Estágio D (31,1%), o que a posiciona no Estágio B com transição para o Estágio C. Nenhuma prática foi assinalada como AL0; 21 das 40 práticas estão em AL3 e apenas o *build* automatizado no CI (IND.01) atingiu AL4, com SAST e SCA no CI em AL3. As menores adoções (AL1) referem-se a CSPM (VER.06) e à observabilidade e Engenharia do Caos em produção (OPE.05 e OPE.06). Por dimensão, o melhor resultado foi em Governança (55,0%) e o menor em Arquitetura e Design (37,5%).

4.3.4 Análise Detalhada da Squad C (Nível 4 — ERP / TI Corporativa)

A Tabela 4.5 detalha a avaliação da Squad C (ERP), cobrindo todos os 40 itens atômicos.

Tabela 4.5: Detalhamento dos resultados do diagnóstico
Zeppelin-AppSec para a Squad C (Nível 4 Purdue — ERP).

Cód.	Dimensão	Nível de Adoção	Peso	AD (%)
AO.01	Governança	AL4	1,00	100%
AO.02	Governança	AL4	1,00	100%
VER.01	Testes e Verificação	AL3	0,60	60%
GOV.01	Governança	AL4	1,00	100%
GOV.02	Governança	AL4	1,00	100%
ARQ.01	Arquitetura e Design	AL4	1,00	100%
ARQ.02	Arquitetura e Design	AL4	1,00	100%
ARQ.03	Arquitetura e Design	AL3	0,60	60%
ARQ.04	Arquitetura e Design	AL3	0,60	60%
COD.01	Desenvol. e Revisão	AL4	1,00	100%
COD.02	Desenvol. e Revisão	AL4	1,00	100%
COD.03	Desenvol. e Revisão	AL4	1,00	100%
COD.04	Desenvol. e Revisão	AL4	1,00	100%
ARQ.05	Arquitetura e Design	AL3	0,60	60%
ARQ.06	Arquitetura e Design	AL4	1,00	100%
COD.05	Desenvol. e Revisão	AL3	0,60	60%
IND.01	Construção e Impl.	AL4	1,00	100%
IND.02	Construção e Impl.	AL4	1,00	100%
VER.02	Testes e Verificação	AL4	1,00	100%
VER.03	Testes e Verificação	AL4	1,00	100%
VER.04	Testes e Verificação	AL3	0,60	60%
ARQ.07	Arquitetura e Design	AL3	0,60	60%
ARQ.08	Arquitetura e Design	AL4	1,00	100%
IND.03	Construção e Impl.	AL4	1,00	100%
IND.04	Construção e Impl.	AL4	1,00	100%
IND.05	Construção e Impl.	AL4	1,00	100%
IND.06	Construção e Impl.	AL4	1,00	100%
VER.05	Testes e Verificação	AL3	0,60	60%
VER.06	Testes e Verificação	AL3	0,60	60%
VER.07	Testes e Verificação	AL4	1,00	100%
OPE.01	Operações e Obs.	AL4	1,00	100%
OPE.02	Operações e Obs.	AL4	1,00	100%
OPE.03	Operações e Obs.	AL4	1,00	100%
OPE.04	Operações e Obs.	AL4	1,00	100%
GOV.03	Governança	AL3	0,60	60%
GOV.04	Governança	AL4	1,00	100%

Continua na próxima página

Cód.	Dimensão	Nível de Adoção	Peso	AD (%)
OPE.05	Operações e Obs.	AL3	0,60	60%
OPE.06	Operações e Obs.	AL3	0,60	60%
OPE.07	Operações e Obs.	AL4	1,00	100%
OPE.08	Operações e Obs.	AL4	1,00	100%

A Squad C registrou $AD_{\text{global}} = 88,7\%$, com maturidade elevada e homogênea entre os estágios (de 85,0% a 92,0%). Nenhuma prática foi assinalada abaixo de AL3: 28 das 40 práticas estão em AL4 (institucionalizadas) e as 12 restantes em AL3, entre elas *Quality Gates*, DAST/IAST e CSPM. Construção e Implantação atingiu 100,0%, enquanto Testes e Verificação foi a dimensão de menor pontuação (77,1%).

4.4 Avaliação dos Requisitos (R) e Critérios (C)

Os resultados demonstraram o atendimento dos requisitos do artefato:

- **C1 (Exequibilidade/DX):** tempo médio de preenchimento de *[PREENCHA: informar o tempo médio, em minutos, de preenchimento por squad]*, a ser comparado ao limite de 30 minutos estabelecido em R1.
- **C2 (Capacidade Discriminatória):** o índice AD diferenciou com clareza as três squads segundo seus níveis Purdue ($AD_{\text{global}} = 20,3\%$ no N2 OT, 47,0% no N3 MES e 88,7% no N4 ERP; R3 atendido).

Capítulo 5

Discussão e Considerações Finais

5.1 Contribuições para a Base de Conhecimento (Ciclo de Rigor)

A pesquisa estende a teoria de Engenharia de Software Contínua ao formalizar o modelo evolutivo StH-AppSec e ao disponibilizar o instrumento Zeppelin-AppSec. A principal contribuição reside no catálogo de 40 afirmações atômicas, rastreável ao OWASP SAMM v2.0 e ao OWASP DSOMM v5.0.2, associado à escala de institucionalização AL0 a AL4 e ao cálculo do Grau de Adoção (AD), expresso pelas Equações 3.1 e 3.2.

5.2 Implicações Práticas e de Gestão (Ciclo de Relevância)

Para a indústria, o Zeppelin-AppSec oferece um instrumento prático, gratuito e de rápida aplicação (< 30 minutos), permitindo que lideranças de engenharia e de AppSec identifiquem gargalos em suas pipelines sem a necessidade de consultorias externas onerosas e demoradas.

5.3 Ameaças à Validade

[PREENCHA: Discuta as ameaças à validade interna, externa, de construção e de conclusão do estudo, incluindo o tamanho reduzido da amostra (uma única avaliação por squad, em três squads), a perspectiva única de cada respondente (sem triangulação entre papéis) e o caráter autorreportado das respostas.]

5.4 Síntese das Realizações

A pesquisa atingiu seus objetivos ao formalizar o StH-AppSec, construir o Zeppelin-AppSec com 40 afirmações atômicas e avaliá-lo empiricamente em três squads classificadas pelo Modelo Purdue, com uma única avaliação por squad.

5.5 Trabalhos Futuros

Recomenda-se a evolução do artefato com a criação de uma plataforma web automatizada de diagnóstico, a condução de estudos longitudinais de acompanhamento, a ampliação da amostra com mais squads e mais de um respondente por squad (permitindo a triangulação de percepções entre papéis) e a adição de módulos de inteligência artificial agêntica para recomendação de roadmaps.

Referências Bibliográficas

- BARCELLOS, M. P.; SANTOS, G.; CONTE, T. U.; TRINKENREICH, B.; MATSUBARA, P. G. F. Organizing Empirical Studies as Learning Iterations in Design Science Research Projects. *Simpósio Brasileiro de Qualidade de Software (SBQS)*, 2022.
- BRASOVEANU, R.; KARABULUT, Y.; PASHCHENKO, I. Security Maturity Self-Assessment Framework for Software Development Lifecycle. *IEEE Access*, v. 10, p. 124500–124518, 2022.
- FUCCI, D.; ALÉGROTH, E.; FELDERER, M.; JOHANNESSON, C. Evaluating Software Security Maturity Using OWASP SAMM: Different Approaches and Stakeholders Perception. *Journal of Systems and Software*, v. 214, p. 112062, 2024.
- HEVNER, A. R. The Three Cycle View of Design Science Research. *Scandinavian Journal of Information Systems*, v. 19, n. 2, p. 87–92, 2007.
- JÚNIOR, P. S. S.; BARCELLOS, M. P.; RUY, F. B.; OMÊNA, M. S. Flying over Brazilian Organizations with Zeppelin: A Preliminary Panoramic Picture of Continuous Software Engineering. *XXXVI Brazilian Symposium on Software Engineering (SBES)*, p. 1–10, 2022.
- KHAN, R. A.; KHAN, S. U.; KHAN, H. U.; ILYAS, M. Security Assurance Model of Software Development for Global Software Development Vendors. *IEEE Access*, v. 10, p. 5456–5481, 2022.
- MIHELIČ, A.; VRHOVEC, S.; MARKELJ, B.; HOVELJA, T. Delegation-Based Agile Secure Software Development Approach for Small and Medium-Sized Businesses. *IEEE Access*, v. 12, 2024.
- MOYÓN, F.; ANGERMEIR, F.; MENDEZ, D. Industrial Challenges in Secure Continuous Development. *International Conference on Software Engineering: Software Engineering in Practice (ICSE-SEIP)*, p. 309–312, 2024.
- NÄGELE, S.; KORN, L.; MATTHES, F. Adoption of Information Security Practices in Large-Scale Agile Software Development: A Case Study in the Financial Sector. *IEEE Transactions on Software Engineering*, v. 49, n. 8, p. 4120–4138, 2023.

- NÚÑEZ, J. C. S.; LINDO, A. C.; RODRIGUEZ, P. G. A Preventive Secure Software Development Model for a Software Factory: A Case Study. *IEEE Access*, v. 8, p. 108649–108661, 2020.
- OLSSON, H. H.; ALAHYARI, H.; BOSCH, J. Climbing the “Stairway to Heaven”: A Multiple-Case Study Exploring Barriers in the Transition from Agile Development to Continuous Deployment. *38th Euromicro Conference on Software Engineering and Advanced Applications (SEAA)*, p. 392–399, 2012.
- OPDENBUSCH, J. C.; SHANTHAKUMAR, S.; SASSE, M. A.; GUTFLEISCH, M. Enabling Security Champions with Breakout Action Groups (BAGs): A Longitudinal Case Study. *ACM Transactions on Software Engineering and Methodology*, v. 35, n. 1, p. 1–28, 2026.
- PEFFERS, K.; TUUNANEN, T.; ROTHENBERGER, M.; CHATTERJEE, S. A Design Science Research Methodology for Information Systems Research. *Journal of Management Information Systems*, v. 24, n. 3, p. 45–77, 2007.
- RAMIREZ, R.; AIELLO, A.; LINCKE, S. J. A Survey and Comparison of Secure Software Development Standards. *IEEE Access*, v. 8, 2020.
- VOGGENREITER, M.; ANGERMEIR, F.; MOYÓN, F.; SCHÖPP, U.; BONVIN, P. Automated Security Findings Management: A Case Study in Industrial DevOps. *International Conference on Software Engineering: Software Engineering in Practice (ICSE-SEIP)*, p. 301–312, 2024.